SecureCorp Security Engagement — Week 2

Red Team Assessment Report

Target: 10.10.10.10 (Metasploitable2) | Attacker: Kali Linux VM (10.10.10.5) | Lab network: Isolated Host Only — no external route

Overview

This report documents Week 2 of the SecureCorp security assessment engagement: the Red Team phase. All activity was executed from the attacker VM (Kali Linux, 10.10.10.5) against the isolated lab target (Metasploitable2, 10.10.10.10) over a Host Only virtual network with no route to any external or production system, in line with the engagement's Rules of Engagement.

Week 2 covers eight tasks: network discovery and enumeration, mapping the target's two attack surfaces, one real service exploitation to a shell, DVWA application-layer attacks (brute force, SQL injection, XSS, command injection), and brute-force assessments of the FTP and SSH services. All eight tasks are complete, with CVSS v3.1 scoring now added for every finding and a consolidated Attack Log below.

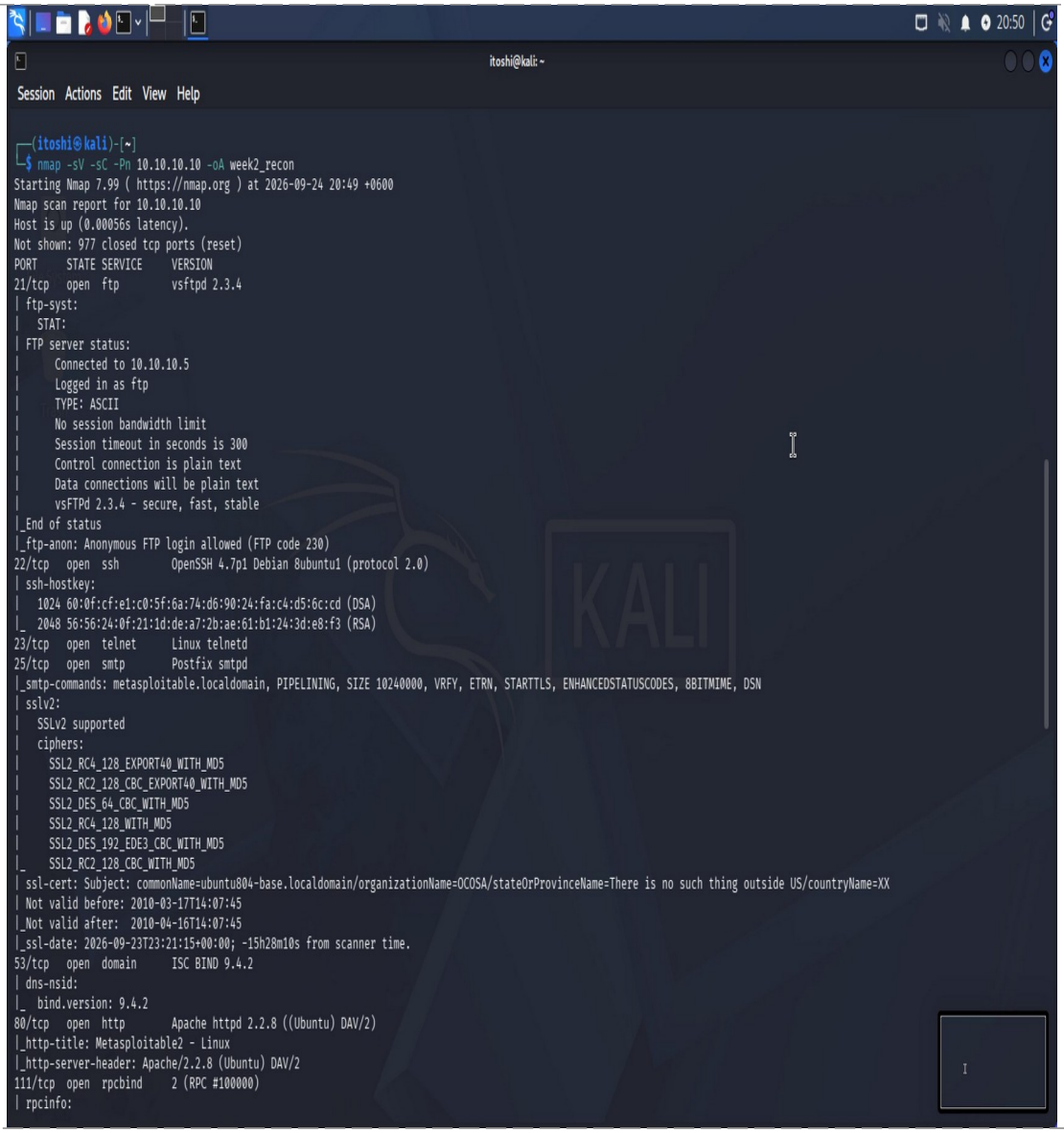
Pre-Attack Baseline

Target IP	10.10.10.10 (Metasploitable2, isolated lab network)
Attacker IP	10.10.10.5 (Kali Linux VM, confirmed via ip a)
DVWA	Loads normally at 10.10.10.10/dvwa; login page reachable
FTP / SSH	Both reachable from the attacker VM prior to testing
Log box	Quiet / baseline confirmed at start of Week 3, Task 3.1

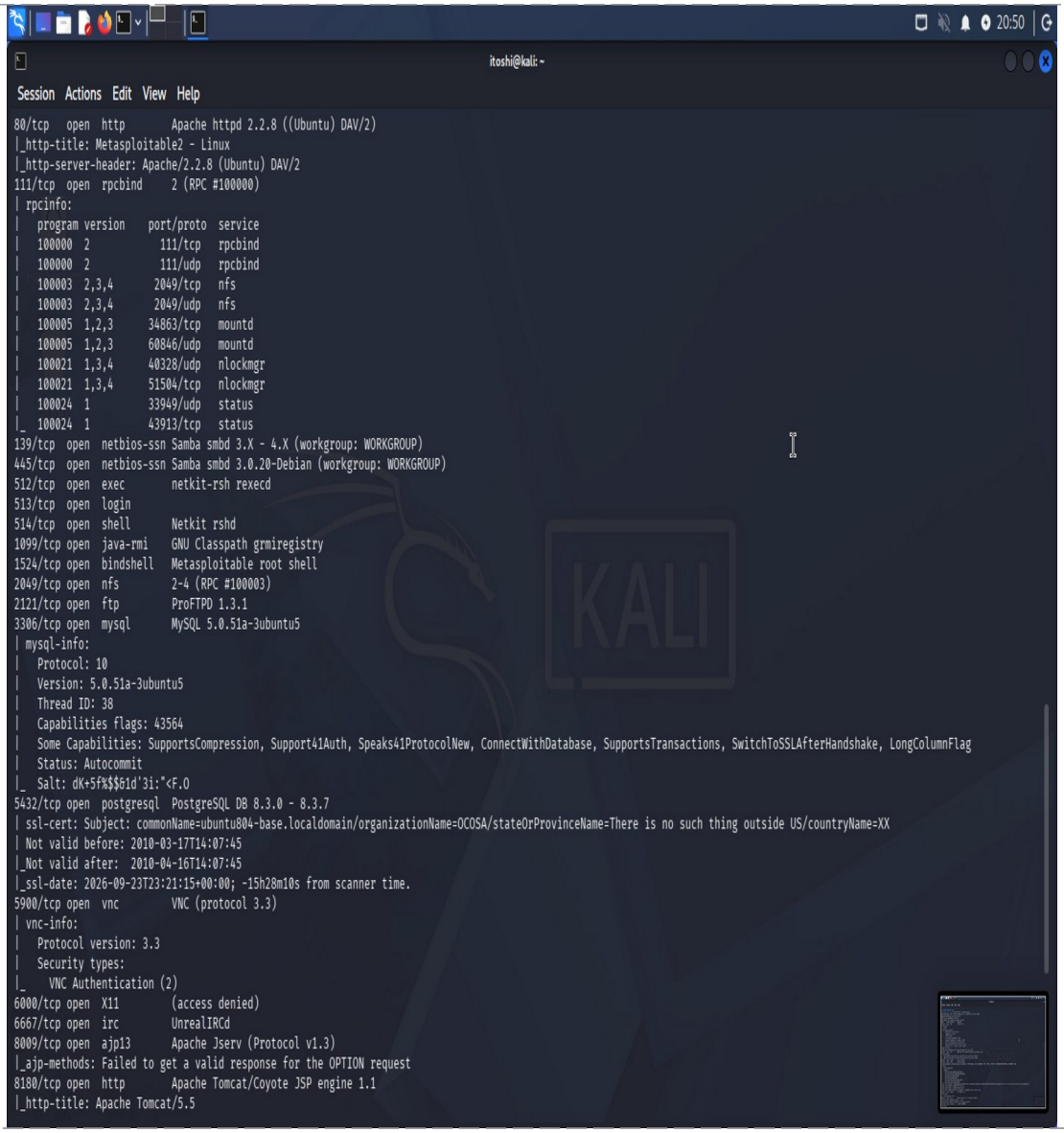
Task 2.1 — Network Discovery

Objective: identify the target's IP, open ports, running services and versions, and the attack surface each represents — before any exploitation.

Method: nmap -sV -sC -Pn 10.10.10.10 -oA week2_recon from the attacker VM.



W2-T2.1-nmap-scan.png (1 of 3) — scan start: FTP, SSH, Telnet, SMTP, DNS, HTTP



W2-T2.1-nmap-scan.png (2 of 3) — RPC services, Samba, NFS, MySQL, PostgreSQL, VNC, Tomcat



W2-T2.1-nmap-scan.png (3 of 3) — remaining services and host script results (SMB OS discovery, clock skew)

Task 2.2 — Attack-Surface Mapping

Objective: map the target's two attack surfaces separately — the DVWA web application and the underlying network services.

Target: 10.10.10.10 (SecureCorp customer portal / Metasploitable2)

Application Map (DVWA modules)

Module	What it does
Brute Force	Login form — vulnerable to password guessing
Command Injection	Takes an IP, passes it unsanitized to a shell ping command
SQL Injection	User ID field — query built by string concatenation, no sanitization
XSS (Reflected/Stored)	Name/Message fields — no output encoding, scripts execute
File Upload	Accepts any file type including .php — no server-side validation

Network-Service List (from Task 2.1 nmap scan)

Port	Service	Version / Notes
21	ftp	vsftpd 2.3.4 (backdoored — exploited in Task 2.3)
22	ssh	OpenSSH
23	telnet	
25	smtp	
80	http	Apache — hosts DVWA
3306	mysql	MySQL
5432	postgresql	PostgreSQL 8.3.0–8.3.7
5900	vnc	VNC protocol 3.3
6667	irc	UnrealIRCd
8180	http	Apache Tomcat/Coyote JSP engine 1.1

W2-T2.2-attack-surface-map.png — DVWA application map and network-service list derived from the Task 2.1 nmap scan

Task 2.3 — Exploit One Real Service Vulnerability

Objective: go from a scan finding to code execution on the target — a known, documented vulnerability confirmed via searchsploit and exploited to a shell.

Service / CVE	vsftpd 2.3.4 backdoor (CVE-2011-2523)
Tool / PoC	Metasploit — exploit/unix/ftp/vsftpd_234_backdoor
Source IP → Target IP	10.10.10.5 → 10.10.10.10
Proof of access	Root shell obtained; id, hostname, and /etc/passwd read confirm access



W2-T2.3-vsftpd-shell.png — id (uid=0/root), hostname (metasploitable), and /etc/passwd confirming root shell access

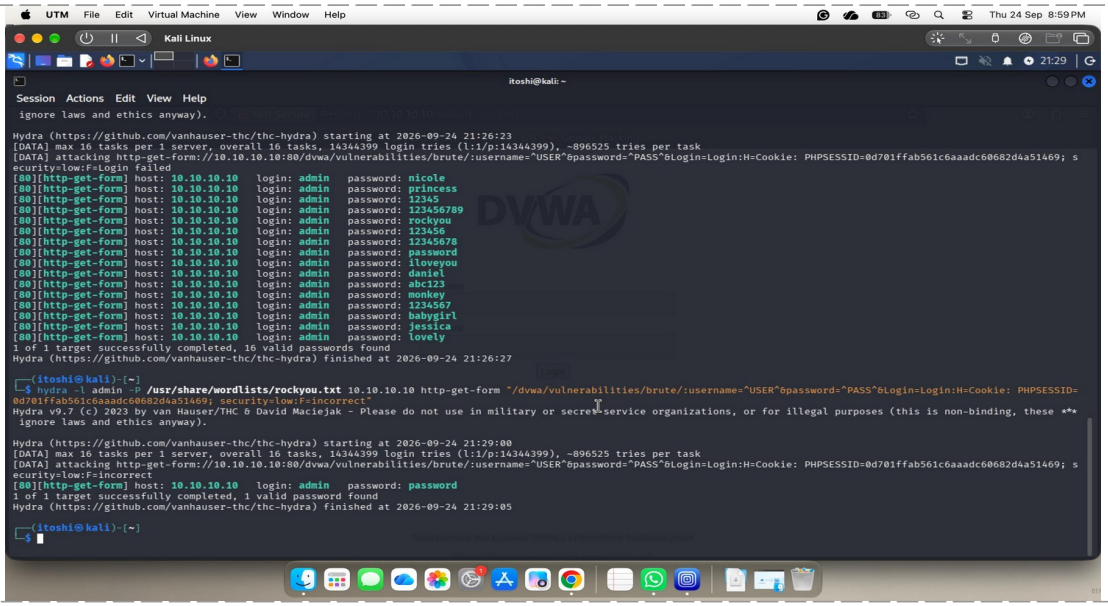
CVSS v3.1 Score

CVSS Vector	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
Base Score	10.0 — Critical
Justification	Remote (AV:N), trivially reliable exploitation (AC:L), no credentials required (PR:N), no victim interaction (UI:N), impact confined to the exploited host (S:U), with complete confidentiality, integrity, and availability compromise (C:H/I:H/A:H) via unrestricted root shell access.

Task 2.4 — DVWA Brute Force

Objective: credential attack against the DVWA portal login (Brute Force module, security = Low), using a small realistic password list.

Source IP → Target	10.10.10.5 → 10.10.10.10 (DVWA)
Tool	Hydra v9.7 — http-get-form module
Wordlist	/usr/share/wordlists/rockyou.txt (username fixed: admin)
Result	Valid password identified for the admin account — 'password'

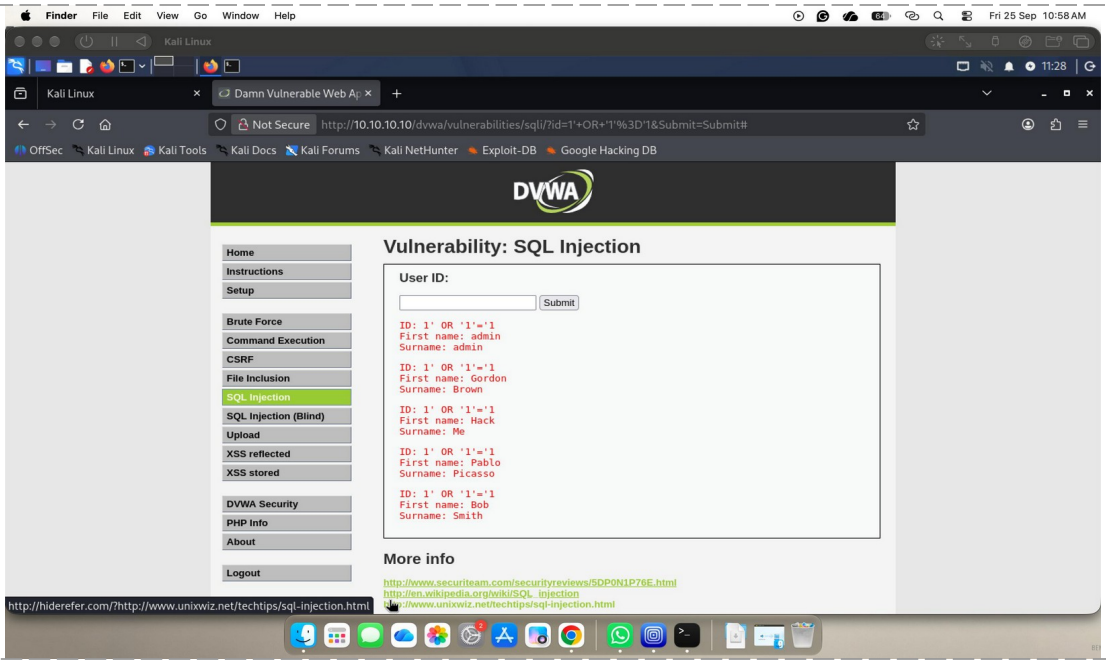


W2-T2.4-dvwa-bruteforce.png — Hydra output against the DVWA login form, confirming a valid admin credential

Task 2.5 — SQL Injection

Objective: extract data the DVWA portal should protect, via unsanitized input in the SQL Injection module (security = Low).

Target	DVWA — SQL Injection module (/dvwa/vulnerabilities/sqli/)
Target IP / Port	10.10.10.10 / 80 (HTTP)
Attack type	SQL Injection — CWE-89
Payload (probe)	' — confirmed unsanitized input via MySQL syntax error
Payload (exploit)	1' OR '1'='1
Result	Query returned all 5 user records (admin, Gordon Brown, Hack Me, Pablo Picasso, Bob Smith)
Detection status	Manual (no SIEM deployed in Core path)



W2-T2.5-sqli-payload.png — payload in the User ID field and the full 5-record user list returned

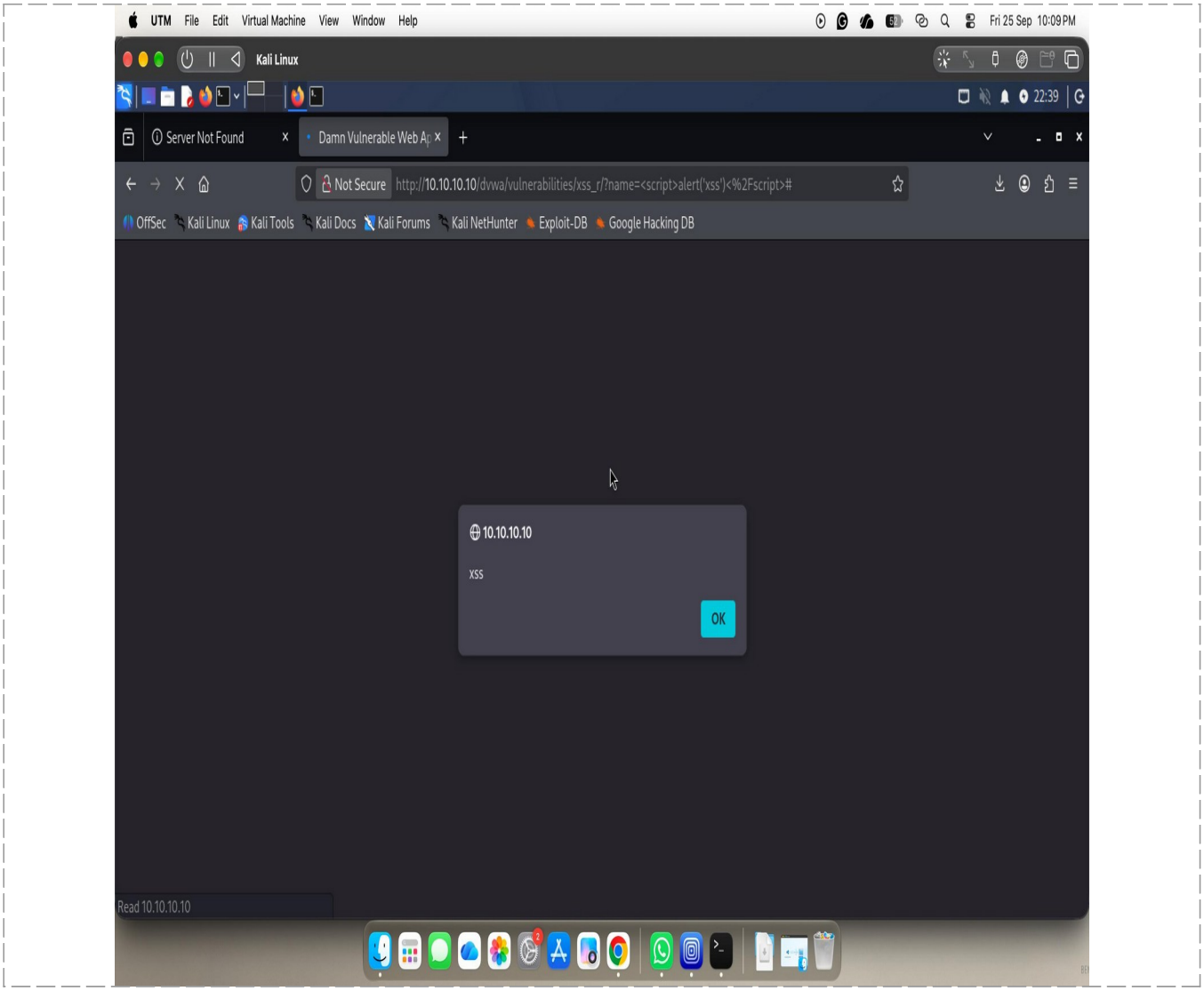
CVSS v3.1 Score

CVSS Vector	CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:N/A:N
Base Score	6.5 — Medium
Justification	Remote via browser (AV:N), reliable single-payload exploitation (AC:L), requires an authenticated DVWA session (PR:L), no victim interaction (UI:N), impact confined to the application's own database (S:U). Full read access to all user records (C:H); no data was modified or deleted and no service disruption occurred (I:N/A:N).

Task 2.6 — XSS (Reflected) and Command Injection

Part A — Reflected XSS

Target	DVWA — XSS reflected module
Target IP / Port	10.10.10.10 / 80 (HTTP)
Attack type	Cross-Site Scripting (reflected) — CWE-79
Payload	<script>alert('xss')</script>
Result	Alert dialog fired with text 'xss', confirming the input was reflected and executed as active script



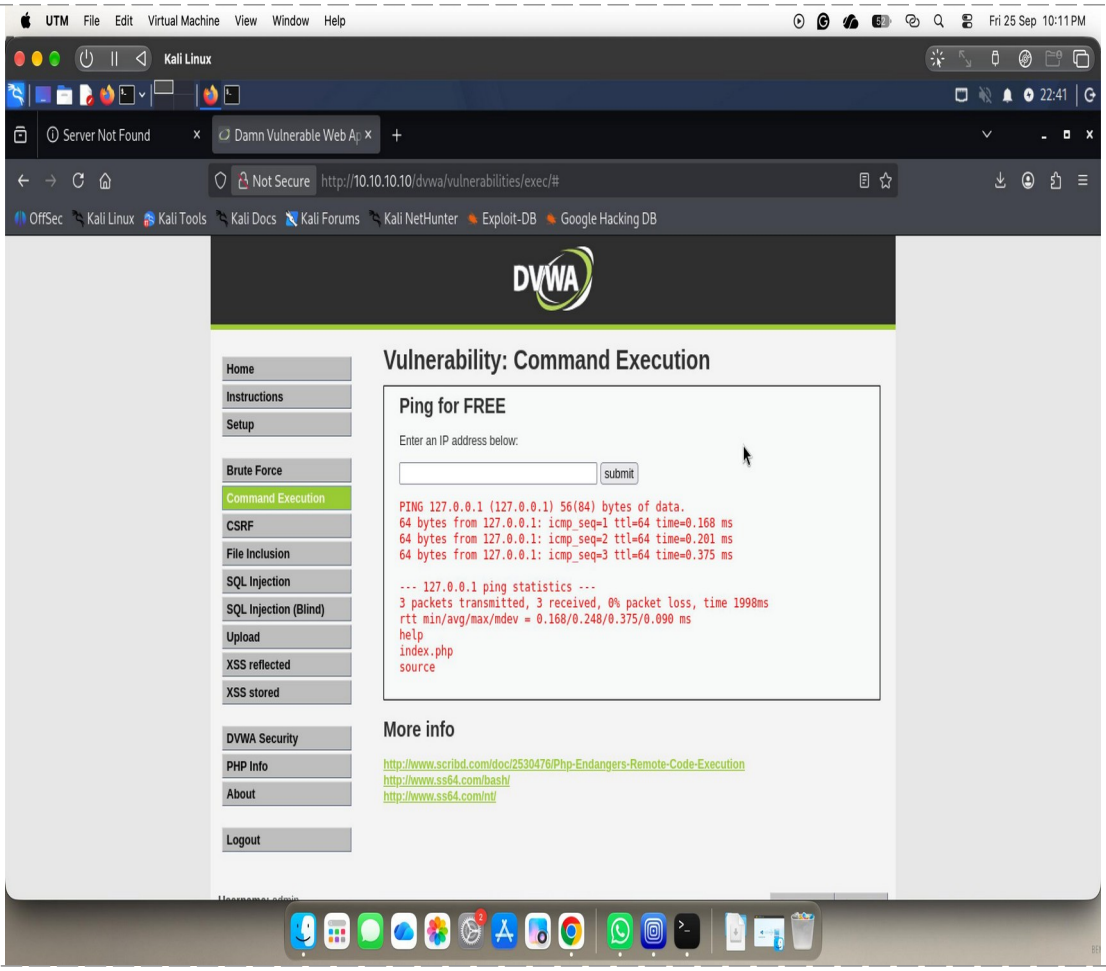
W2-T2.6-xss-payload.png — payload in the URL bar and the resulting JavaScript alert box

CVSS v3.1 Score — Reflected XSS

CVSS Vector	CVSS:3.1/AV:N/AC:L/PR:L/UI:R/S:C/C:L/I:L/A:N
Base Score	5.4 — Medium
Justification	Remote (AV:N), reliable (AC:L), requires an authenticated session to reach the vulnerable field (PR:L). Reflected XSS requires a victim to click a crafted link (UI:R), and impact lands in the victim's browser session — a separate security scope from the server (S:C). Script execution could allow session/credential theft (C:L/I:L); no availability impact demonstrated (A:N).

Part B — OS Command Injection

Target	DVWA — Command Execution module ("Ping for FREE")
Target IP / Port	10.10.10.10 / 80 (HTTP)
Attack type	OS Command Injection — CWE-78
Baseline test	127.0.0.1 → normal ping output returned, confirming the module functions as expected
Payload	127.0.0.1; ls
Result	Ping output returned followed by a directory listing appended after it, confirming user input was passed unsanitized to a shell
Detection status	Manual (no SIEM deployed in Core path)



W2-T2.6b-cmdinj-payload.png — ping output followed by the appended directory listing

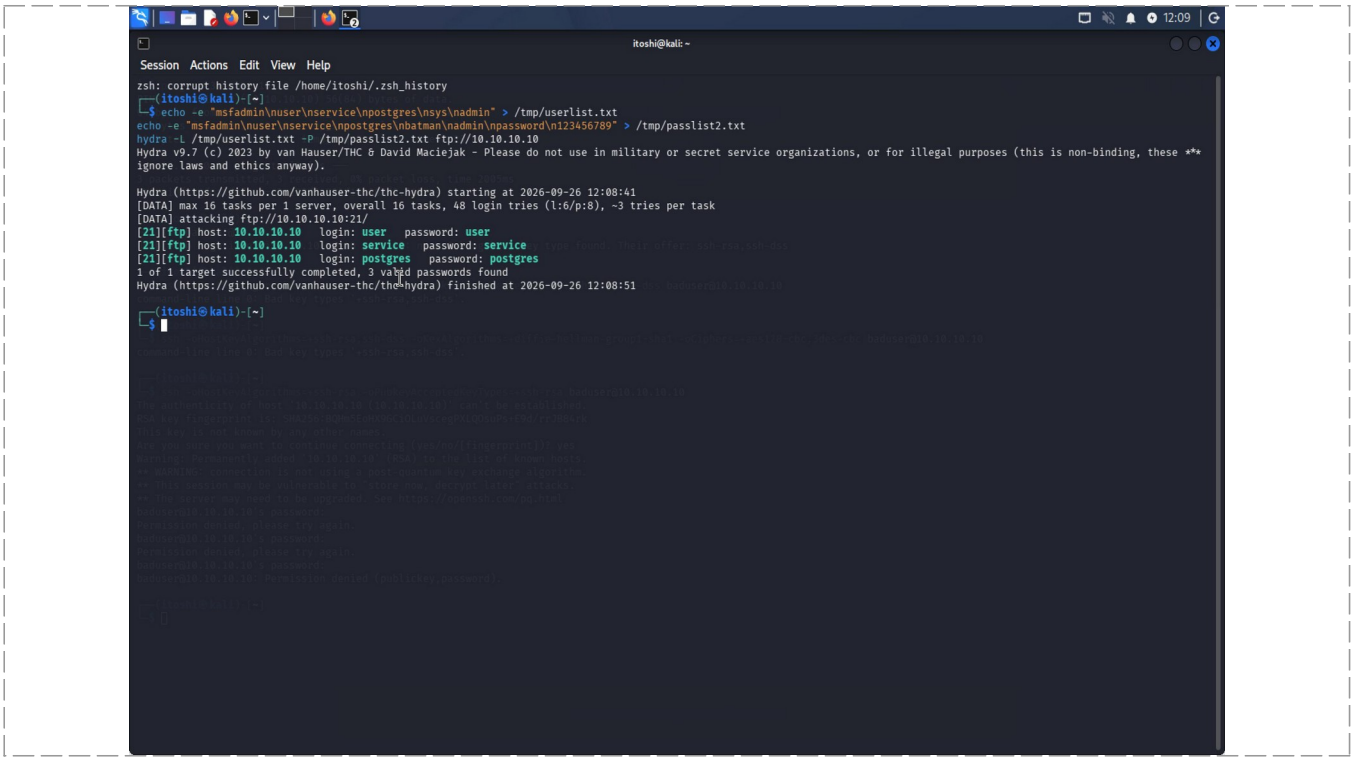
CVSS v3.1 Score — Command Injection

CVSS Vector	CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H
Base Score	8.8 — High
Justification	Remote (AV:N), reliable (AC:L), requires an authenticated DVWA session (PR:L), no victim interaction (UI:N), impact confined to the web server's own host (S:U). Arbitrary OS command execution as the web server user gives full read/write/disruption capability within that account's privileges (C:H/I:H/A:H).

Task 2.7 — FTP Brute Force

Objective: assess the FTP service's authentication mechanism as a network-service attack surface distinct from DVWA and SSH, and identify which target-side log will need to be checked for it in Week 3.

Target IP / Port	10.10.10.10 / 21 (FTP)
Attack type	Credential brute force — CWE-307
Tool	Hydra v9.7
Usernames tested	msfadmin, user, service, postgres, sys, admin
Result	Valid FTP credentials found: user:user, service:service, postgres:postgres (3 of 6 tested accounts)
Expected log source	Target FTP daemon log (vsftpd.log)
Detection status	Manual (no SIEM deployed in Core path)



W2-T2.7-ftp-bruteforce.png — Hydra terminal output confirming three valid FTP credential pairs

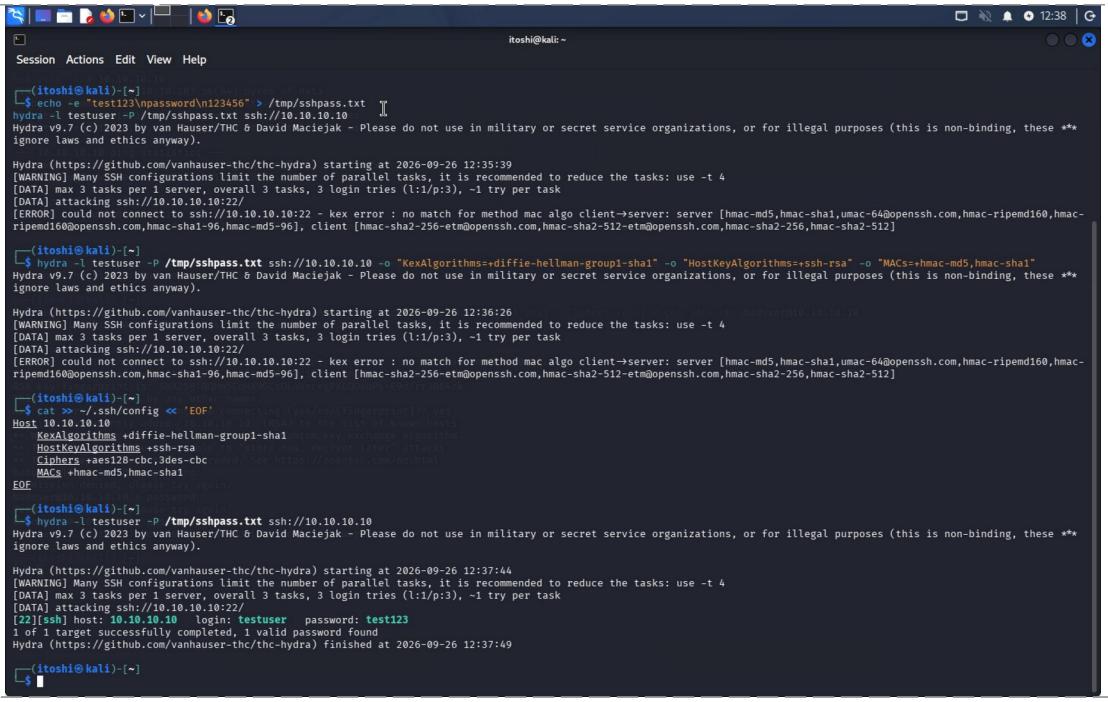
CVSS v3.1 Score

CVSS Vector	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:N
Base Score	6.4 — Medium
Justification	Remote (AV:N), reliable (AC:L), no prior credentials needed to attempt the attack (PR:N), no victim interaction (UI:N), impact confined to the target host (S:U). Three low-privilege service accounts were compromised, granting limited file read/write access via FTP only (C:L/I:L); no availability impact (A:N).

Task 2.8 — SSH Brute Force

Objective: brute-force the SSH login and observe how the attempt will surface in the target's authentication log during the Week 3 investigation.

Target IP / Port	10.10.10.10 / 22 (SSH)
Attack type	Credential brute force — CWE-307
Tooling note	Initial Hydra attempts failed with a key-exchange/MAC algorithm mismatch against the legacy OpenSSH version; resolved via SSH client config overrides
Username tested	testuser
Result	Valid SSH credential identified: testuser:test123
Detection status	Manual (no SIEM deployed in Core path)



W2-T2.8-ssh-bruteforce.png — Hydra output confirming a valid SSH credential after adjusting legacy algorithm settings

CVSS v3.1 Score

CVSS Vector	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:L
Base Score	7.3 — High
Justification	Remote (AV:N), reliable once legacy algorithm compatibility was configured (AC:L), no prior credentials needed to attempt the attack (PR:N), no victim interaction (UI:N), impact confined to the target host (S:U). The compromised account grants a full interactive shell, enabling limited reading, modification, and disruption of that account's own files and processes (C:L/I:L/A:L).

Consolidated Attack Log (Appendix B Format)

Attack	Target/Module	Method	Start–End	Source IP	Result	Detection
2.3 Real Exploit	vsftpd 2.3.4 (port 21)	Metasploit vsftpd_234_backdoor	2026-09-24	10.10.10.5	Root shell, confirmed via id/hostname/passwd	Manual
2.4 DVWA Brute Force	DVWA login	Hydra, rockyou.txt	2026-09-24 21:26–21:29	10.10.10.5	admin:password found	Manual
2.5 SQL Injection	DVWA SQLi module	Manual, browser	2026-09-25	10.10.10.5	All 5 user records dumped	Manual
2.6a XSS	DVWA XSS reflected	<script>alert('xss')</script>	2026-09-25 22:39	10.10.10.5	Alert fired, confirmed reflected	Manual
2.6b Command Injection	DVWA Command Exec	127.0.0.1; ls	2026-09-25 22:41	10.10.10.5	Directory listing returned	Manual
2.7 FTP Brute Force	FTP (port 21)	Hydra	2026-09-26 12:08	10.10.10.5	3 valid creds (user, service, postgres)	Manual
2.8 SSH Brute Force	SSH (port 22)	Hydra	2026-09-26 12:35–12:37	10.10.10.5	testuser:test123 found	Manual

Summary and Next Steps

All eight of Week 2's tasks are complete with recorded evidence, CVSS v3.1 scoring on every finding, and a consolidated Attack Log. The attacker IP (10.10.10.5) is confirmed in the Pre-Attack Baseline above.

The w2-attacked snapshots for all three VMs have been taken, closing the Week 2 readiness gate. All findings carry forward into the Week 3 blue-team log review.